ITAI 3375 — Module 12

Lab 12: Governance & Privacy Audit

Real regulations, real dataset, real decisions — no memorization required **SLOs:** 5 **Points:** 100

Format: Home assignment

Overview

This lab asks you to look at a real dataset through a compliance lens. You will identify which regulations apply to it, spot the privacy risks, and document what a responsible organisation would need to do before using that data to train an AI model.

You do not need to be a lawyer. You do not need to memorise regulation numbers. You need to think carefully about data, people, and risk — and write down what you find. Every deliverable in this lab is a short written response, a filled-in table, or a simple checklist.

> **Format:** This is entirely written work. No Python, no notebooks, no code required. A Word document, Google Doc, or PDF is all you need to submit.

> **Which dataset to use:** Use the dataset you worked with in Lab 10. If you used a clearly fictional or toy dataset that contains no personal information, email the instructor to discuss an alternative — most real datasets will work fine.

Part 1 — What Regulations Apply? (Evening 1, ~45 minutes)

Before any organisation uses a dataset for AI, someone needs to ask: which rules govern this data? This part asks you to do exactly that for your Lab 10 dataset.

1a. Three questions to answer

Read your dataset description and the source you downloaded it from, then answer:

- Who are the data subjects? (Real people? Businesses? Events? Animals? If real people — what kind: patients, customers, employees, members of the public, children?)
- Where was the data collected? (US only? EU? International? Unknown?)
- What kind of information does it contain? (Names, ages, health data, financial data, location, behaviour, opinions, biometric data — or none of these?)

1b. Regulation identification table

Using your answers above, decide which of these regulations likely apply. Check all that apply and give a one-sentence reason for each check.

Regulation	Applies? (Y/N/Maybe)	One-sentence reason
GDPR (EU data protection)	__N_	There are no identifiers in the data that would allow EU citizens to be identified, and it only comes from public service requests in New York City.
CCPA (California consumer privacy)	__N_	The dataset is exclusive to NYC 311 complaints and has nothing to do with businesses or consumers in California.
HIPAA (US health data)	__N_	The information is not protected health information or medical records covered by HIPAA, even though a few complaint categories touch on housing/safety issues (such as heat/hot water).
EU AI Act (if building an AI system with this data)	_Maybe_	Regardless of the provenance of the training data, the Act may apply to AI systems that are sold in the EU or that have an impact on EU citizens; its applicability is determined by the final system's risk assessment and deployment location, not by the US source of this open data.
No personal data regulations apply	__Y_	The dataset does not qualify as personal data under the major privacy laws since the chosen fields do not contain names or other direct identifiers, and the location data is too imprecise to properly re-identify individuals.

What to submit for Part 1

- Your three answers to the questions in 1a.
- The completed regulation table — all five rows filled in with Y / N / Maybe and a reason.

> **Tip:** 'Maybe' is a perfectly valid answer. If you genuinely cannot tell whether EU residents are included in a public dataset, say so and explain why it is uncertain. Honest uncertainty earns full credit.

Part 2 — Spot the Privacy Risks (Evening 1, ~45 minutes)

Even datasets that are technically public or anonymised can carry privacy risks. This part asks you to look at your dataset more carefully than you did in Lab 10 and flag what could go wrong if it were used carelessly.

2a. Field-by-field scan

Go through each column in your dataset and classify it using this simple scheme:

Category	Description
Direct identifier	Directly identifies a real person: name, email, phone, SSN, passport number, exact address.
Quasi-identifier	Could identify someone in combination with other fields: age, ZIP code, job title, date of birth, general location.
Sensitive attribute	Sensitive about a person but not identifying alone: health condition, income range, religion, political view, sexual orientation.
Non-personal	Contains no information about real individuals: product prices, event counts, weather readings, stock tickers.

For each column in your dataset, write the column name and its category. A simple table or list is fine.

2b. Risk assessment

Based on your field scan, answer these four questions in a paragraph or short bullet list:

- Is re-identification possible? Could someone combine two or more quasi-identifiers to work out who a record belongs to?
- Is there any special category data? (Health, biometrics, religion, political views, financial details — these get extra protection under GDPR Art. 9 and similar rules.)
- Could this data be used to discriminate? (Could an AI trained on this data treat people differently based on race, gender, age, disability, or other protected characteristics?)
- What is the biggest privacy risk you see? State it in one sentence.

What to submit for Part 2

- Column classification list or table.
- Answers to the four risk assessment questions — two to four sentences each is enough.

> **Reality check:** If your dataset genuinely contains no personal data (e.g. it is weather readings or product prices), say so clearly in Part 2 and explain why you are confident. That is a legitimate and complete answer.

Column	Category	Brief justification
unique_key	Non-personal	System-generated request ID; does not identify any person.
created_date	Quasi-identifier	Timestamp that can help narrow identity when combined with location.
closed_date	Quasi-identifier	Same as created_date.
agency	Non-personal	City agency name only.
complaint_type	Non-personal	High-level category of the request.
descriptor	Quasi-identifier / Sensitive attribute*	Detailed complaint text; occasionally reveals sensitive living conditions.
incident_zip	Quasi-identifier	Classic location quasi-identifier.
city	Quasi-identifier	Neighbourhood / local area name.
status	Non-personal	Administrative status of the ticket.
borough	Quasi-identifier	Coarse location (one of five boroughs).
latitude	Quasi-identifier	Precise geographic coordinate.
longitude	Quasi-identifier	Precise geographic coordinate.

2b. Risk assessment

- **Is re-identification possible?**
- Yes, to a certain extent. A record could be narrowed down to a specific building or even a small group of residents by combining multiple quasi-identifiers, particularly created/closed date + incident ZIP (or borough/city) + precise latitude/longitude + complaint type/descriptor, especially for rare or highly specific complaints. Since there are no direct identifiers, full re-identification of named individuals is challenging; however, linkage attacks utilizing external public records are still possible in certain situations.
- Is there any special category data?

  Not in the traditional meaning of GDPR Article 9 (no financial information, biometrics, religion, political beliefs, or specific medical diagnoses). A subset of descriptor values, such as "HEAT/HOT WATER – ENTIRE BUILDING," "Animal-Abuse – Neglected," and specific plumbing or sanitation problems, can, however, subtly disclose delicate living conditions or possible health/safety vulnerabilities of the residents at that location, so they call for additional attention.

Could this data be used to discriminate?
Yes, indirectly. Neighborhood demographics (income, race, age distribution, disability rates) may be correlated with complaint kinds or locations by an AI model trained to predict urgency or agency action. Even if there are no clear racial, gender, or age fields in the raw data, the system may consistently underserve or overserve some protected groups if such patterns are employed for resource allocation or priority scoring without safeguards.

Biggest privacy risk
A realistic danger of re-identifying certain households or persons through linking with other public or commercial datasets is created when precise geolocation (latitude/longitude) is combined with timestamps and complaint details.

Part 3 — Fill In the Compliance Checklist (Evening 2, ~45 minutes)

This is the checklist that a responsible data team would run through before using a dataset to train an AI model. Go through it for your dataset and answer each item honestly.

#	Checklist Item	Your Answer
1	Is the dataset licence confirmed as allowing use in AI training?	*Yes / No / Unclear — explain*
2	Is the data source (who collected it, when, how) documented?	*Yes / No — note what is missing*
3	Does the dataset contain personal data?	*Yes / No / Uncertain*
4	If yes: is there a legitimate reason to use it? (public interest, open consent, legal requirement, etc.)	*State the reason, or N/A*
5	Does the dataset contain any of the GDPR special categories (health, biometrics, religion, etc.)?	*Yes / No*

6	Could a model trained on this data produce discriminatory outputs?	*Yes / No / Possibly — explain briefly*
7	Is there a retention policy — how long can this data be kept?	*Note the stated policy, or 'Not specified'*
8	If a data subject asked you to delete their record, could you?	*Yes / No / Difficult — explain*
9	Is the data from a country or region with strong privacy laws (EU, California, Canada, UK)?	*Yes / No / Unknown*
10	Would a privacy-conscious employer be comfortable with how you obtained and plan to use this data?	*Yes / No — brief explanation*

What to submit for Part 3

- The completed checklist — all 10 items answered in the right-hand column.
- For any item where your answer is 'Unclear' or 'Not specified', add one sentence explaining what information you would need to give a definitive answer.

#	Checklist Item	My Answers
1	Is the dataset licence confirmed as allowing use in AI training?	**Unclear** — NYC Open Data publishes the file as public open-government data usable for educational and analysis purposes, but the licence text does not explicitly address AI model training. **I would need the full official licence / terms-of-use page from data.cityofnewyork.us to confirm whether commercial or model-training use is permitted.**
2	Is the data source (who collected it, when, how) documented?	**Yes** — Collected by New York City agencies through the 311 system and published on NYC Open Data; the API endpoint and continuous update from 2020–present are clearly stated.
3	Does the dataset contain personal data?	**Uncertain** — No direct identifiers are present, yet quasi-identifiers (lat/long, ZIP, timestamps, detailed descriptors) make limited re-identification possible.
4	If yes: is there a legitimate reason to use it? (public interest, open consent, legal requirement, etc.)	**Public interest** — The City of New York releases the data to support transparency and improvement of municipal services; responsible educational and research use (including AI experimentation) aligns with that purpose.

#	Checklist Item	My Answers
5	Does the dataset contain any of the GDPR special categories (health, biometrics, religion, etc.)?	**No** — There are no explicit health diagnoses, biometric data, religious or political views, or similar fields.
6	Could a model trained on this data produce discriminatory outputs?	**Possibly** — Complaint-type and location patterns can correlate with neighbourhood demographics; without fairness controls an urgency model could systematically under- or over-serve protected groups.
7	Is there a retention policy — how long can this data be kept?	**Not specified** — NYC Open Data imposes no retention limit on downloaders. **I would need an official statement from the City or a project-specific data-governance policy** **stating how long the extracted sample may be retained.**
8	Has data minimisation been applied (only fields necessary for the AI use case kept)?	**Yes** — Only 12 columns relevant to urgency classification and basic location analysis were selected; many original fields were excluded.
9	Are there any contractual, terms-of-use, or platform restrictions on downstream AI use?	**Unclear** — The public dataset page does not list explicit AI-related restrictions. **I would need the complete Terms of Use and any API usage policy on the NYC Open Data portal.**
10	Has a privacy / data-protection impact assessment (or equivalent risk review) been considered?	**No** — No formal DPIA or structured privacy-risk assessment is documented in the Lab 10 notebook . A lightweight review of re-identification and fairness risks (as done in Part 2) would be the minimum next step.

Part 4 — Add a Governance Section to Your Data Card (Evening 2, ~45 minutes)

Pull out the Data Card you wrote in Lab 10 (Step 5) and add a new section called Governance & Privacy. Fill in each field below. Short, honest answers are exactly right.

Governance Field	What to Write
Applicable Regulations	List the regulations you identified in Part 1. If none apply, say so.

Personal Data Present?	Yes / No. If yes, what type (direct identifiers, quasi-identifiers, sensitive attributes)?
Biggest Privacy Risk	One sentence from Part 2b.
Legitimate Basis for AI Use	Why is it acceptable to use this data for AI training? (Open licence, public interest, no personal data, etc.)
Retention Recommendation	How long should this dataset be kept? When should it be reviewed for deletion?
Who Should NOT Use This Data	One to three sentences. What kinds of AI applications or organisations should not use this dataset?

> **Keep it grounded:** Write about your actual dataset. One accurate, specific sentence about your real data is worth more than three generic sentences copied from a textbook.

What to submit for Part 4

- Your updated Data Card with the new Governance & Privacy section added — or just the new section as a standalone document.

Governance & Privacy Section

For the Data Card – NYC 311 Service Requests from 2020 to Present

Governance Field Content

Applicable Regulations None of the major personal-data regimes apply: GDPR (US-only data,

no identifiable EU residents), CCPA (no California consumers), and

HIPAA (not health records). The EU AI Act may apply only if a model
trained

on this data is later placed on the EU market.

Personal Data Present? No direct identifiers. Quasi-identifiers are present (created_date,
closed_date,

incident_zip, city, borough, latitude, longitude, and some descriptors).

A few descriptors can act as sensitive attributes when they reveal

housing or safety conditions.

Biggest Privacy Risk The combination of precise latitude/longitude with timestamps and
complaint details

creates a realistic risk that specific households could be re-
identified through

linkage with other public datasets. |

Legitimate Basis for AI Use Public-interest / open-government purpose: the City of New York
releases the

data on NYC Open Data specifically to support transparency and
analysis of municipal

services; educational AI experimentation falls within that purpose.

Retention Recommendation Keep the extracted sample only for the duration of the current
research or

model-development project (recommended maximum 12–24
months).

Review and delete or refresh the local copy once the urgency-
classification experiments

are complete.

Who Should NOT Use This Data Organisations building production systems that make automated
decisions about individual

residents example., prioritising housing inspections or emergency
responses

should not use the raw lat/long fields without additional
aggregation or fairness controls.

Commercial entities seeking to re-identify complainants or link the
data to private customer

records should also refrain.

Grading Rubric (100 Points)

Grading rewards honest, specific thinking. Generic answers or blank fields receive no credit. A wellreasoned 'I am not sure because...' always earns partial credit.

Criterion	Full Credit	Partial Credit	Pts
Part 1 — Regulations	Three questions answered; all five regulation rows completed with Y/N/Maybe and a reason.	Three questions answered; regulation table incomplete or reasons missing for some rows.	**25**
Part 2 — Privacy Risks	All columns classified; all four risk questions answered with specific observations about the actual dataset.	Most columns classified; at least two risk questions answered.	**25**
Part 3 — Checklist	All 10 items answered; unclear/missing answers explained with what information is needed.	At least 7 items answered; most with brief explanations.	**25**
Part 4 — Data Card	All 6 governance fields completed with specific, dataset-specific content.	At least 4 fields completed with substantive content.	**25**
TOTAL			**100**